

DOSSIER D'ARCHITECTURE

SL1PCONNECT — Virtualisation · Conteneurisation · Orchestration

Client : SL1PCONNECT S.A.S. | Périmètre : Refonte de l'infrastructure cible (Siège + Plateforme IoT) | Version : 4.1
— Juin 2026

Convention de lecture. Chaque choix distingue **POC** (preuve de concept déployée et vérifiée) de **CIBLE** (état de production visé). Le document décrit l'architecture livrée, puis sa trajectoire d'industrialisation (synthétisée en section 4).

Sommaire

1. Résumé exécutif
 2. Schéma d'architecture
 3. Choix techniques justifiés
 4. **Synthèse : maquette (POC) → infrastructure cible**
 5. Durcissement et preuves techniques
 6. Comparatif des solutions
 7. Plan d'adressage
 8. Plan de migration
 9. Critères de recette et traçabilité
 10. Risques résiduels et trajectoire
 11. Budget et synthèse
-

1. Résumé exécutif

SL1PCONNECT exploite une plateforme IoT de santé (sous-vêtements connectés, capteurs textiles) traitant des **données de santé relevant de l'article 9 du RGPD**. L'infrastructure historique a grandi par accumulation, sans politique de sécurité : serveurs physiques non virtualisés au siège, hôte conteneurisé unique exposé au cloud, conteneurs exécutés en root, secrets en clair, absence de supervision et de reproductibilité.

L'architecture cible repose sur quatre piliers :

1. **Virtualisation** — consolidation des serveurs du siège, haute disponibilité et snapshots.
2. **Conteneurisation durcie** — re-conteneurisation des services IoT : exécution non privilégiée, suppression des capacités, secrets en fichiers, réseaux cloisonnés, reverse proxy TLS.
3. **Orchestration proportionnée** — Docker Compose durci en preuve de concept, Kubernetes léger (k3s) en cible.
4. **Reproductibilité** — Infrastructure-as-Code et chaîne d'intégration continue avec analyse de vulnérabilités.

La preuve de concept est fonctionnelle : dix conteneurs en service sur trois réseaux cloisonnés, suite de tests automatisés au vert (dont le jeu d'une injection SQL), isolation réseau vérifiée (seuls les ports 80 et 443 exposés) et gestion des secrets sans fuite. La section 4 synthétise les écarts restants entre cette preuve de concept et la cible de production.

2. Schéma d'architecture

ZONE A – SIÈGE (ON-PREMISE) [CIBLE : Proxmox VE]

Internet

[Pare-feu périmétrique]

[DMZ]—[Pare-feu interne]

VLAN AD	– Annuaire + RODC + MFA
VLAN WEB	– Boutique (haute disponibilité)
VLAN DNS	– DNS autoritaire + DNSSEC
VLAN BDD	– Base boutique
VLAN METIER	– Forge, coffre secrets, ERP SaaS
VLAN POSTES	– Postes de travail
VLAN QUARANTAINE	– Systèmes legacy isolés

| IPSec site-à-site → sites distants

ZONE B – PLATEFORME IoT (CLOUD HDS) [POC : 10 conteneurs]

Internet →HTTPS→ [reverse-proxy nginx – 80/443 TLS]

| (seul service publié)

thread-api
(API mobile)
JWT HS256

taylor-panel
(back-office)
login local + CSRF

fabric-watch
(supervision)
dashboards

===== RÉSEAU edge =====

===== RÉSEAU data (internal – AUCUNE route Internet) =====

stitch-processor
(traitement santé)
clé API

db-velvet
(PostgreSQL – données santé)

===== RÉSEAU monitoring =====

prometheus · loki · node-exporter · promtail

(collecte des logs par fichiers, pas via docker.sock)

Secrets : montés en fichiers (convention *_FILE)

IaC : Ansible

CI/CD : lint + validation + tests + scan de vulnérabilités

3. Choix techniques justifiés

3.1 Hyperviseur — Proxmox VE 8.x [CIBLE]

Critère	Proxmox VE	ESXi	Hyper-V
Licence / CapEx	Open-source, 0 €	Payant	Licences Windows
Haute disponibilité	Cluster natif	vSphere HA	Failover
Snapshots	ZFS / Ceph	VMDK	Oui
Infrastructure-as-Code	Provider Terraform	Oui	Partiel

Justification : suppression du coût de licence, snapshots ZFS avant chaque changement, provisionnement par code, consolidation des serveurs physiques hétérogènes du siège en machines virtuelles à haute disponibilité.

3.2 Reverse proxy — Nginx

Choix : Nginx, **unique conteneur publiant des ports** (80/443), terminaison TLS et routage par nom d'hôte.

Justification : standard éprouvé, image minimale, contrôle fin de la configuration TLS, centralisation des en-têtes de sécurité. Réduit la surface d'exposition à un seul point d'entrée maîtrisé.

3.3 Orchestration — Compose durci [POC] → k3s [CIBLE]

Critère	Compose durci	k3s	Kubernetes complet
Complexité	Faible	Faible	Élevée
Politiques réseau	Non	Oui	Oui
Haute disponibilité	Non	Oui	Oui

Justification : Compose durci suffit à démontrer cloisonnement et durcissement. k3s en cible apporte les politiques réseau (isolation renforcée des données de santé) et la redondance multi-nœuds, sans la lourdeur d'un Kubernetes complet, surdimensionné pour le périmètre.

3.4 Modèle d'authentification — adapté par service

Chaque service applique le mécanisme proportionné à sa surface d'exposition, avec une **convention de hachage commune** garantissant la cohérence cryptographique.

Service	Mécanisme	Mesures
API mobile	Jeton signé JWT (HS256, expiration 1 h)	Validation stricte des entrées, comparaison à temps constant
Back-office	Authentification locale (rôle administrateur)	Requêtes préparées, jeton anti-CSRF, session durcie
Traitement	Clé d'API (en-tête dédié)	Comparaison à temps constant

Justification : le découplage évite un point de confiance unique tout en conservant un format de hachage portable entre les langages des services.

3.5 Hachage des mots de passe — PBKDF2-HMAC-SHA256

Choix : PBKDF2-HMAC-SHA256, format de stockage interopérable (itérations + sel + condensat).

Justification : le condensat doit être produit et vérifié par plusieurs langages sans dépendance binaire native ; PBKDF2 y répond nativement avec un format de chaîne portable et une comparaison à temps constant. Une montée vers Argon2id est prévue en cible (recommandation actuelle), avec re-hachage transparent à la connexion.

3.6 Gestion des secrets — fichiers [POC] → coffre-fort [CIBLE]

POC : secrets montés en fichiers (jamais en variables d'environnement ni dans le code), génération par source d'aléa cryptographique, exclusion du dépôt et contrôle anti-fuite avant chaque livraison de code.

Cible : coffre-fort de secrets (rotation automatique, journal d'audit, injection dynamique).

3.7 Supervision — métriques, logs et tableaux de bord

Pile Prometheus / Loki / Grafana. La collecte des logs s'effectue **par lecture des fichiers**, sans accès au socket du moteur de conteneurs — supprimant le vecteur d'évasion vers l'hôte présent dans l'infrastructure d'origine.

3.8 Reproductibilité — Ansible [POC] → Ansible + Terraform [CIBLE]

Déploiement reproductible par playbook Ansible et commande unique. En cible, ajout de Terraform pour le provisionnement des machines virtuelles.

3.9 Sauvegarde — stratégie 3-2-1 chiffrée

Niveau	Contenu	Chiffrement
Local	Snapshots / export base	AES-256
Distant	Réplication hors-site	AES-256
Cloud	Stockage objet	AES-256 + GPG

Sauvegarde chiffrée avec rotation et procédure de restauration vérifiable.

4. Synthèse : maquette (POC) → infrastructure cible

Le tableau ci-dessous consolide, domaine par domaine, **l'état actuel de la preuve de concept** et **ce qui reste à implémenter pour la production**. Il constitue la feuille de route d'industrialisation.

Domaine	Maquette (POC) — état actuel	Cible production — à ajouter
Virtualisation	Stack déployée sur l'hôte existant ; conteneurs sur une VM unique	Cluster Proxmox VE multi-nœuds, HA, snapshots ZFS, consolidation des serveurs du siège
Orchestration	Docker Compose durci , mono-hôte	k3s multi-nœuds, politiques réseau (deny-all + autorisation explicite), redondance
Reverse proxy / TLS	Nginx + certificat auto-signé	Certificats reconnus (ACME / Let's Encrypt ou gérés)
Secrets	Docker secrets en fichiers	Coffre-fort (Vault) : rotation automatique, audit, injection dynamique
Hachage mots de passe	PBKDF2-HMAC-SHA256	Argon2id (re-hachage transparent à la connexion)
Trafic inter-services	HTTP en clair sur réseau Docker cloisonné	TLS mutuel (mTLS) via service mesh
Chiffrement au repos	Absent (données sur volume en clair)	Chiffrement de volume (LUKS / dm-crypt) sur l'hébergement HDS
TLS base de données	Désactivé (réseau interne)	Activé, sslmode=verify-full
Supervision ↔ base	Compte base à droits étendus	Compte en lecture seule dédié
Sauvegarde	Scripts prêts, restauration non encore exécutée	Drill de restauration régulier + 3-2-1 hors-site chiffré
CI/CD	Lint + validation + tests + scan Trivy	+ audits de dépendances (Python/PHP/Node), détection de secrets , SBOM
Couverture de tests	Centrée sur l'API mobile	Tests back-office et traitement
Infrastructure-as-Code	Ansible (configuration)	+ Terraform (provisionnement des VM)
Hébergement données santé	VM cloud standard	Offre certifiée HDS + contrat associé
Siège (Zone A)	Hors périmètre de la maquette	VLANs , MFA annuaire, RODC, DNSSEC, quarantaine legacy, IPSec inter-sites

Lecture : la colonne de gauche est **livrée et vérifiable** aujourd'hui ; la colonne de droite constitue le **plan d'industrialisation**, dont le calendrier figure en section 8 et les risques associés en section 10.

5. Durcissement et preuves techniques

5.1 Mesures appliquées à chaque conteneur

Mesure	Effet
Exécution non privilégiée	Aucun compte root dans le conteneur
Suppression de toutes les capacités	Aucun privilège Linux par défaut
Interdiction d'élévation de privilèges	Bloque l'escalade par binaires setuid
Système de fichiers en lecture seule	Image immuable, écriture limitée à un espace temporaire
Limites de ressources	Protection contre l'épuisement
Sondes de santé	Supervision de l'état réel des services
Réseau de données cloisonné	Base et traitement sans route Internet

5.2 Abandon vérifié des privilèges

Les services concernés démarrent brièvement en root pour préparer leurs secrets, puis **abandonnent définitivement leurs privilèges** avant d'exécuter le processus applicatif. La lecture de l'état du processus principal confirme que les ensembles de capacités *permitted* et *effective* sont **nuls** : une compromission applicative ne permet aucune remontée vers root.

```
CapPrm: 0000000000000000 → aucune capacité permise
CapEff: 0000000000000000 → aucune capacité effective
CapInh: 0000000000000000 → aucune capacité héritée
```

5.3 Résilience

En cas d'arrêt non sollicité d'un conteneur, la politique de redémarrage le relance automatiquement ; le retour à l'état sain est constaté en moins de vingt secondes, sans intervention.

6. Comparatif des solutions

6.1 Hyperviseur

Solution	Forces	Faiblesses	Score
Proxmox VE 8	Gratuit, HA, ZFS, Terraform	Support communautaire	9/10
ESXi	Mature	Coût, fin de vie	5/10
Hyper-V	Intégré Windows	Licences	6/10

6.2 Reverse proxy

Solution	Forces	Faiblesses	Score
Nginx	Performant, TLS fin, écosystème	Configuration moins intuitive	9/10
Caddy	HTTPS automatique	Moins de réglages	8/10
Traefik	Découverte Docker	Apprentissage	7/10

6.3 Orchestrateur

Solution	Forces	Faiblesses	Score
k3s (cible)	Léger, politiques réseau, HA	Apprentissage	9/10
Compose durci (POC)	Simple, reproductible	Pas de HA	8/10
Swarm	Intégré	Déprécié	4/10

6.4 Hachage des mots de passe

Solution	Forces	Faiblesses	Score
PBKDF2 (POC)	Interopérable, natif	Résistance GPU moyenne	8/10
Argon2id (cible)	Référence actuelle	Dépendances	9/10
bcrypt	Mature	Portabilité	7/10

7. Plan d'adressage

7.1 Zone A — Siège (cible Proxmox)

VLAN	Réseau	Usage
VLAN 10 — DMZ	10.10.0.0/24	Reverse proxy entrant
VLAN 20 — Annuaire	10.10.1.0/24	AD DS, RODC, MFA
VLAN 30 — Web	10.10.2.0/24	Boutique haute dispo
VLAN 40 — DNS	10.10.3.0/24	DNS + DNSSEC
VLAN 50 — BDD	10.10.4.0/24	Base boutique
VLAN 60 — Métier	10.10.5.0/24	Forge, coffre, ERP
VLAN 70 — Postes	10.10.6.0/24	Postes de travail
VLAN 80 — OT	10.10.7.0/24	Sites industriels
VLAN 99 — Quarantaine	10.10.99.0/24	Systèmes legacy isolés

7.2 Zone B — Cloud (réseaux conteneurs)

Réseau	Type	Rôle
edge	Exposé via proxy	Proxy ↔ services front
data	Cloisonné (internal)	Base + traitement, aucune route Internet
monitoring	Interne	Supervision

Conteneur	Réseaux	Port publié
reverse-proxy	edge	80, 443
API mobile	edge + data	—
back-office	edge + data	—
supervision	edge + data	—
traitement	data	—
base de données	data	—
pile métriques/logs	monitoring	—

Règle d'or : seuls les ports 80 et 443 sont joignables depuis l'extérieur. La cible k3s applique des politiques réseau « tout interdit, autorisation explicite ».

8. Plan de migration

Phase	Contenu
Phase 1	Socle d'infrastructure et mesures de sécurité prioritaires
Phase 2	Migration du siège (Zone A)
Phase 3	Industrialisation de la plateforme IoT (Zone B)

Phase 1 — Mesures prioritaires

Action	Risque évité
Révocation des accès obsolètes	Compromission active
Rotation des secrets partagés	Exfiltration
Isolation des systèmes legacy	Propagation de logiciels malveillants
Activation de l'authentification multifacteur	Vol d'identifiants
Retrait de l'accès au socket conteneur	Évasion vers l'hôte
Mise en place hyperviseur et coffre-fort	Socle technique

Phase 2 — Siège (du moins critique au plus critique)

DNS → boutique web (haute disponibilité, coupure < 2 h) → base de données (export puis bascule < 30 min) → annuaire (RODC maintenu, MFA) → services métier (forge, coffre, ERP en SaaS).

Phase 3 — Plateforme IoT

Re-conteneurisation durcie → gestion des secrets → chaîne d'intégration complète → supervision → recette finale (isolation, résilience, restauration). Mise en œuvre progressive des éléments de la colonne « cible » de la section 4.

Réversibilité

Phase	Retour arrière	Délai
2	Maintien des serveurs d'origine + DNS à faible durée de cache	< 5 min
3	Image précédente conservée + snapshot	< 2 min

9. Critères de recette et traçabilité

9.1 Critères de validation

Critère	Méthode de vérification	Statut
Isolation réseau (80/443 uniquement)	Scan de ports	Validé
Absence de secrets en clair	Revue des modifications et de l'environnement	Validé
Rejet des injections SQL	Suite de tests automatisés	Validé
Hachage robuste et comparaison à temps constant	Tests unitaires	Validé
Capacités résiduelles nulles	Lecture de l'état du processus	Validé
Redémarrage automatique	Simulation de panne	Validé
Déploiement reproductible	Playbook et commande unique	Validé
Restauration de sauvegarde	Procédure de restauration	Planifié

9.2 Traçabilité — exigence vers composant

Exigence	Composant
Terminaison TLS	Configuration du reverse proxy
Hachage et jeton signé	Service API mobile
Requêtes préparées, anti-CSRF, session durcie	Back-office
Authentification par clé d'API	Service de traitement
Cloisonnement et durcissement	Description d'orchestration
Génération des secrets et du certificat	Script d'initialisation
Reproductibilité	Playbook d'infrastructure

10. Risques résiduels et trajectoire

Risque	Gravité	Statut	Trajectoire cible
Procédure de restauration non encore exécutée	Moyen	Scripts disponibles	Exécution de validation planifiée
Supervision connectée avec un compte base étendu	Moyen	Documenté	Compte en lecture seule dédié
Données de santé non chiffrées au repos	Moyen	Assumé en POC	Chiffrement de volume (LUKS)
Trafic interne entre services en clair	Faible	Réseau cloisonné	TLS mutuel (service mesh)
Certificat auto-signé	Faible	POC	Certificats reconnus (ACME)
Couverture de tests centrée sur l'API mobile	Faible	Suite existante	Extension aux autres services

11. Budget et synthèse

11.1 Budget

Poste	CapEx	OpEx annuel
Briques open-source (hyperviseur, orchestration, coffre, supervision)	0 €	0 €
Réutilisation du matériel existant	0 €	—
Hébergement certifié données de santé	—	~3 600 €
Stockage de sauvegarde	—	~600 €
Total	~0 €	~4 200 €

11.2 Synthèse des livrables

Livrable	Statut
Dossier d'architecture	Fourni
Preuve de concept fonctionnelle (10 conteneurs)	Vérifiée
Durcissement et preuves	Fourni
Infrastructure-as-Code	Fourni
Chaîne d'intégration continue	Fournie

Document d'architecture — SL1PCONNECT S.A.S. — Version 4.1. Technologies : Nginx · PBKDF2-HMAC-SHA256 · JWT HS256 · clé d'API · validation stricte · secrets en fichiers · Ansible · Compose durci → k3s.